Indirect Prompt Injection□ Lethal Trifecta

Agentic AI□ □□□□ □□□□ □

□□□ □□ □□, □□ □□□ □□, □□ □□·□□□□ □□□
□ □□□ □ □□□ □□□ □□□□ □□□□□ □□□□□□.

□□ □□□: □ □□ □□□□□□ □ □□ □□□ □□ □□□ □□□□□.

□ Agentic AI□ □□ □□□ □ □□□□

□□□ □□□ □□□ □□ □□ capability□ □□□

- □□□□, □□□, □□, DB, API, MCP□ □ □□□□ □□□□□.
- □□□ □□□ □□ □□□□ □□ context □ □□□ □□□□.
- □□□ □□□ □□□ □□□ □□□□ □□ □□□ □□□□□.

□□□□ "□□"□ □□□ "□□□"□ □□□ □

- □ □□□, □□□, □□, □□, PDF □□ □□□ □□□ □□ □ □□□□.
- □ □□□ □□ □□·□□·□□ □□□ □□ □ □□ □□□□□.
- □□□ □□□ □□ □□□□ □□□ □□ □□□ □□□□□.

Indirect Prompt Injection□□ □□□□

DEFINITION

- □□□□ □□ □□□□ □□ □□ □□□□ □□□ agent context□ □□□ □□□□ □□□ □□□ □□□□□.
- □□ □□□ □ □□□, □□□ □□, □□ □□, □□ □□, □□ □□, PDF, MCP □□□□ □□□□□.
- □□□ injection□ □□, □□ □□□□ "□□□ □□ □□□"□□ □□□□ □□ □□□□□.

```
User request → Agent fetches untrusted content → Malicious instruction enters context →
Model reprioritizes actions → Sensitive read or outbound action occurs
```

Lethal Trifecta: □ □□□ □□□ □□□ □□□□□

1. Untrusted content

□, □□□, □□, □□, □□ □□, □□ MCP □□□□ □□□ □ □□ □□

2. Sensitive data access

□□ □□, □□□, □□□ □□, □□, DB, □□□□□ □□ □□ □□□ □□ □□

3. External action

□□ □□, □□□ □□, □□ □□, □□□ □□ □□, □□ □□, □□ □□

□□ □□

□ □□□ □ □□□□ □□□□ □□□ □□□ □□□ □□□ "□□□ □□ □□" □□ □□□ □ □□□□.

□□ □□ □□

1. □□□□ □□ □□□□□□ □□□ □□□ □□□ □□□□□□□.

2. □□□□ "□ □□ □□□□ □□ □□ □□□" □□ □□ □□□ □□□□.

3. □□□□□□ □□ □□□ □□ □□ □□ □□□ □□ □□□ □□□□□.

4. □□ □□□ □□□ □□□□□ □□□ secret, token, □□ □□□ □□□ □□□□□□□.

5. □□ □□□□ □□ □□, Slack, webhook, □□□□ □□□□ □□□□ □□□□□.

□ "□ □□ □□□□□"□□□□ □ □□□

□□□□□ □□ □□□□ □□ □□□ □□

- □□□ □□□□□ □□□□□. □□□ □□□ □□ □□□ □□□□.
- □ context□ □□□ □□□□□ □□ □□□ □□□ □□□□□.
- □□ □□□ □□ □□ □□□□□ □□□ □□ □□□ □□□□□.

□□ □□□ □□□ □□□□ □□

- □□□□ □□ □□□□ □□ □□□ □□ □□□□ □□ □□ □□□.
- □□ □□, context □□, □□ □□, egress□ □□□□ □□□□ □□□.
- □ □□□ detection□□ impact containment□□□.

Rule of Two: □□ □□□ □□□□

META AGENTS RULE OF TWO

- □ □□, □ □□ □□, □ □□□ □□□□ □□ □ □□□ □□□ □□ □□□□.

□□□ □□ □□

□□ □□□□ □□ □□□□ □□

□□ □□□ □□

□□ □□□ □□□ □□□□ □□

□□ □□·□□□□

□□□ □□□□ □□□ □□□ □□□ □□

□□ □□□ "□ □ □□ □□□□ □□"□□□. □□□ □□□ □□ □□□ □□ □□ □□ □□ □□□□□.

Rule of Two: □□□ □□□□ □□□ □□□□

□□ □□	□□ □□	□□
□□ □□ □□ agent	□□□ □□ + □□□ □□	□□ □□□ □□□□□ □□□ □□ □□□ □□□
□□□ □□□ □□ agent	□□□ □□ □□□ + □□ □□	□□□ □□□ □□ □□ □□□ injection surface□ □□
□□ □□ agent	□□□ □□ + □□□□	□□ □□□ □□□ □□□ □□□□ exfiltration□ □□
□□□ agent	□□ □□□ + □□□□	□□ □□□ ingestion□ □□ □□ □□□ □□□□ □

- □ agent□ □□ □□□ □□ □□ □□, □□□ capability□ □□□□ □□ □□□□□.

□□ □□: CaMeL □□ □□

Trusted request□ □□□ planner

- □□□ □□□ □□ plan, code, tool invocation □□□ □□□□.
- □□ □□ □□□ □□□ □□ □□□ □□□ □□□□.
- □□ □□□ □□ □□□ action □□□ □□□□□ □□□□.

Untrusted content□ □□□ extractor

- □□ □□□□ schema □□ □□ □□□□ □□□□□ □□□□□.
- □□□ □□□ □□□□, □□□ □□□ □□□□ □□□ □□□□.
- planner□ □□ □□□ □□□□ □□□ □□□ □□□□.

```
User request → Planner Untrusted content → Extractor → Structured fields Planner →
Restricted executor → Tools under policy
```

□□ □□ 1: Dual LLM □□ □□ □□ □□

□□□ □□□

- Planner□ trusted user request□ □□□□.
- Extractor□ untrusted content□ □□ □□□ □□□ □□□.
- □ □□□ prompt, tool, memory□ □□□□□.

□ □□□□□

- □□ □□□ planning loop □□□ □□ □□□□ □□□□.
- planner□ □□ □□ □□□□ □□□□ □□ □□□□ □□□□□.
- □□□ □□ □□□□□ "□□ □□□ □□□□"□ □□□□□□.

□□ □□□: extractor □□ □□□ JSON schema, enum, bounded field length□□ □□ □□□ □□□ □□ □□□□.

□□ □□ 2: Plan-Then-Execute

□□ □□ plan□ □□

- □□ "□□ □□□□ □□ □□ □□□ □□" □□□ □□□□.
- □□□ □□ executor□ □□□ step□ □□□□□.
- □□□ □□ □□□□ □ □□□ □□□ plan□ □□ □ □ □□ □□□.

□□□ □□□□

- □□□□ □ □□□ □□, □□ □□ □ □□ □□ □□ □□□ □□
- □□ □□□ □□ □□□□ audit log□ □□□ □□ □□
- □□ □□□ allowlist □□□□ □□□□ □□ □□

```
Plan generation → policy review → bounded execution → result summary
```

□□ □□ 3: Code-Then-Execute

□□□□ □□ □□□□ □□ □□□ □□□□ □□□

- planner□ □□ □□ □□ □□□ DSL, typed action list, restricted code□ □□□□□.
- executor□ □□□ □□ □□□ □□□□, □ □ □□□ □□□□□.
- □: `search_docs(query)`, `draft_email(recipient, summary)` □□ bounded action□ □□

□ □□□□□

- □□□□ □□ □□□ □□□ □□□ □□ □□□ □□□□ □□□□□.
- □□ □□ □□□ □□ □□□□ □□□ □□□□ □□ □□□ □□□.
- □□□□ □□ action□ deterministic□□ □□□ □ □□□□.

□□ □□ 4: Structured Extraction□ □□

□□ □□ □□ □□□□ □□ □□

- □: `{invoice_id, amount, sender, due_date}` □ □□
- □□□ □□□ planner□ □□□ □□ □□□ □□□ □□
- □□□□ □□ □□□ □□□, □□□ □□□ □□

□ □□□□

- □□□□ □□ "□□ □□□□ □ URL□ □□□" □□ □□□ □□□□ □□□□□.
- planner□ □□□□ □□□ □□□ □□□ □□□□□.
- PDF, HTML, □□□□□ □□□□ □ □□□ □□ □□□□□□.

□□ □□ 5: Context Minimization

Context□ □□ □□

- □□□ □□ □□□ □□, □□ □□ □□□ □ □□ □□ □□□□.
- □□ □□□□ □□ □□□ □□ context window□ □□ □□□□.
- □□ □□□□ □□□□ □□□ □□ □□□□□.

□□ □□ □□□□

- □□ □□□ □□ RAG □□
- □□ □□□ □□□□□ □□□ □□ □□□□
- □□ □□□ □□ □ □□□ □□ □□□ □□ □□□ agent

□□ □□ 6: Map-Reduce

□□□□ □□ □□□□ □□□□ □□□

- □ □□ □□□□ extractor □□□ □□ □□ □ □□ aggregator□ □□□□.
- □□ □□□ □□ □□□ □□□ □□ □□·□□□ □□□ □□□□.
- □□ □□□ □□ context□ □□□□ □□□ □□ □ □□□□.

□□□□□ □□

- □□ □□□ □□□□ □□□□□.
- □□ □□ provenance□ audit trail□ □□□ □□□□.
- □□□ □□·□□ □□□□ blast radius□ □□□ □ □□□□□□.

□□ □□ 7: Action Selector□ □□ □□□

□□ □□□ □□ □□ □□□ □□

- send mail, post Slack, write ticket, execute command□ □□ selector□ □□
- selector□ □□ □□, □□□ □□□, □□ □□□, approval □□□ □□ □□□.
- □□□□ human approval □□□ □□□□ □□□□.

□□ □□□ □□□□ □ □

- egress allowlist, tool□ scope, read/write □□, request signing
- □□□ □□□ dry-run preview□ diff □□
- □□ □□ □□□□□ □□ □□□ □□□□□ □□ □□ □□□

□□ □□ □□□□□

1. □□ □□□ □□ □□□ □□ □□□□ □□ □□□ □□□□□.

2. planner, extractor, executor□ □□□□ □□ tool scope□ □□□ □□□□□.

3. □□ □□□ □□□□ □□□ allowlist, approval, audit log □□ □□□.

4. structured output, bounded schema, short-lived memory□ □□□□□ □□□.

5. □ □□ □□□ Lethal Trifecta□ □□ □□□□ □□ □□□ □□□ □□□□□.

□□ □□□ □□□□ □

EchoLeak□ □□□ □□

- □□ □□□□□□ □□□ □□□ M365 Copilot□ □□·□□ □□□ □□□□□□.
- □ □ □□ □□□ □□□ □□ □□ □□□ □□□□ zero-click exfiltration □□□ □□□□□□.
- □ □□ □□□□ □□ □□□□□ □□□ tool boundary□ data flow □□□ □ □□□□.

□□

- □□□□ □□□ "□□□ □□ □□□□"□ □□□ "□□□□ □□ □□ □□□ □□□" □□□□□.
- □□ □□□ □□□ □□ □□□ □□□ tool boundary□ action policy□□□.
- □□ agent □□□ architecture □□□□□.

□□

AI agent□ □□□ □□ □□, □□ □□□ □□, □□ □□·□□□□ □□□ □□□ □□□ indirect prompt injection□ □□ □□ □□□ □□□ □□□ □□□□ □□□.

□□□ □□ □□□ "□ □□ □□□□"□ □□□, □ □□□ □ □□□ □ □□□□ □□□ □□□□ □□□ □□□□ □□□□. Lethal Trifecta□ Rule of Two□ □ □□□ □□□□ □□□ □ □□□□□.

□□ □□ 1: □□□ □□

- Not what you’ve signed up for: Compromising Real-World LLM-Integrated Applications with Indirect Prompt Injection
- Defeating Prompt Injections by Design
- CaMeL research artifact (google-research/camel-prompt-injection)
- Operationalizing CaMeL: Strengthening LLM Defenses for Enterprise Deployment
- Design Patterns for Securing LLM Agents against Prompt Injections
- The lethal trifecta for AI agents: private data, untrusted content, and external communication
- Meta: Practical AI Agent Security

□□ □□ 2: □□ □□□□ □□

- OpenAI: Designing AI agents to resist prompt injection
- OpenAI API: Safety in building agents
- OpenAI: Keeping your data safe when an AI agent clicks a link
- OWASP AI Agent Security Cheat Sheet
- OWASP MCP Security Cheat Sheet
- MSRC: How Microsoft defends against indirect prompt injection attacks
- Aim Labs: Breaking down EchoLeak
- Reversec: Design Patterns to Secure LLM Agents In Action